

WWW Security

Module 20

Duration: 26:21

Video: <https://www.youtube.com/watch?v=4t3ot0oUah0>

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Gursimran Singh, Doaba College, Jalandhar

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

0:16 hello everyone this is gur simran Singh welcome to the session of worldwide web security

0:23 www the worldwide web is one of the biggest invention ever it is also the

0:31 biggest information resource of the world it has opened flood gates of information and enables instant access

0:38 to information anywhere anytime and in any format www is now contributing to the

0:46 globalization of production and capital markets by reducing the cost of information and communication the

0:55 www has proved to be a producing ground for a large and growing number of e

1:02 business that carried out most of their sales and services over the Internet the worldwide web is fundamentally a client

1:12 server application running over the internet and TCP IP internets information stored on

1:20 www is in the form of electronic documents called web pages now web browser is used to access the

1:28 information on worldwide web the new services are introduced every day online banking online transactions it requires

1:37 special security attention but web presents new challenges not generally appreciated in the context of Computer

1:46 and Network Security so these are the internet is two-way unlike traditional publishing environment even electronic

1:53 publishing system involving teletext voice response or faxback the web is

2:00 vulnerable to attacks on the web servers over the Internet the web is increasingly serving as a highly visible

2:09 outlet for corporate and product information and as the platform for business

2:16 transactions reputations can be damaged and money can be lost if web servers are

2:23 challenged although web servers are easy to use web servers are relatively easy to configure and manage and web content

2:31 is increasingly easy to develop and underlying software is extraordinary complex

this complex software May hide

2:40 many potential security flaws the short history of the web is filled with the examples of new and upgraded systems

2:49 properly installed that are vulnerable to a variety of security attacks a web server can be exploited as a launching

2:56 pad into corporations or agencies computer complex once the web server is

3:04 subverted and attacker can able to gain access to data and systems not part of the web itself but connected to the

3:13 server at the local site now casual and untrained users are common clients for

3:20 web based services such as users are not necessarily aware of security risk that exist and do not have the tools or

3:29 knowledge is to take effective Contra measures now let's discuss worldwide web

3:36 security threads worldwide web security threads can be grouped in terms of passive and active attacks passive

3:45 attacks include EES dropping on network traffic between browser and server and gaining access to information on a

3:53 website that is supposed to be restricted active attacks include imprison ating another users altering

4:01 4 minutes, 1 second message in transmission between client and server and altering information on a website main WWE security threats can be

4:10 briefed as Integrity threats confidentiality threats authentication threats and

4:18 denial of service attack now we will discuss different threats with consequences and counter measures so

4:25 let's start our discussion with the first security threat that is Integrity threats data integrity means keeping the

4:33 data intact the main threats to data Integrity on worldwide web are modification of user data troan horse

4:41 browser modification of memory modification of message traffic in transmission now the consequences of

4:48 Integrity threats are loss of information compromise of machine vulnerability to all other threats

4:56 countermeasure of Integrity threats is cryptograph traffic check SS now the second threat is confidentiality threat

5:04 the main threats to data confidentiality on worldwide web are EES dropping on the internet theft of information from the

5:13 server theft of data from client and information about network configuration information about which client talks to

5:21 server now consequences of confidentiality threats are loss of information and loss of privacy now cont

5:29 ERS are encryptions and web proxies now next threat is authentication threat the
main threats

5:38 to authentication on worldwide web are impersonating of legal users and data
5:46 forgery consequences of authentication threats are misrepresentation of user
5:52 believe that false information is valid now Contra measures for authentication
threats is use of cryptographic

6:01 6 minutes, 1 second techniques now next threat is that is the most dangerous
denial of service attack the main threat of denial of

6:08 service attacks are killing of user threats flooding machine with bogus requests
filling up disk or memory

6:16 isolating Machine by DNS attacks consequences of denial of service

6:22 attacks are disruptive annoying prevent users from getting work done now counter
measures of denial of service it is very

6:32 difficult to prevent the denial of service attack now there are certain web traffic
security approaches that can

6:39 provide web security the various approaches that have been considered are similar
in the service they provide and

6:47 to some extent in the mechanism that they use but they differ with respect to their
scope and applications and their

6:55 relative location within the tcpip protocol stack now worldwide web security can be
provided on network

7:03 layer transport layer application layer and as well as by using the firewalls now
let's start our discussion with web

7:11 security at Network level IP security is one way to provide web Security on

7:18 network cayer IP security is a collection of protocols designed by the internet
engineering task force to

7:27 provide security for a package at Network level the advantage of using IP security
is that it is transparent to

7:36 end users and applications and provides a general purpose solution further IP

7:42 security includes a filtering capability so that only selected traffic need experience
the overhead of Ip security

7:52 processing the figure that is displayed on the screen represents the use of Ip
security

8:00 to provide the worldwide web security IP security helps in creating

8:08 authenticated and confidential packets for IP layer IP security operates in two

8:15 different modes transparent mode and tunnel mode so in transport mode IP

8:21 security protects what is delivered from the transport layer to the network layer in
other words transport mode protects

8:30 the payload to be encapsulated in the network layer as you can observe in the

8:37 figure note that transport mode does not protect the whole IP header it protects only the packet from the transport layer

8:46 the IP layer payload in this mode the IP security header and trailer are added to the information coming from the

8:55 transport layer the IP header is added later on as you can observe in the figure transport mode is normally used

9:04 when we need host to host protection of data the sending host uses IP security

9:11 to authenticate or encrypt the payload delivered from the transport layer the receiving host uses IP security to check

9:20 the authentication or decrypt the IP packet and deliver it to the above layer that is transport layer now the second

9:29 mod is tunnel mode in tunnel mode IP security protects the entire packet it takes an IP packet includes the header

9:38 applies IP security methods to the entire packet and then adds a new IP header as you can observe in the figure

9:47 the new IP header has different information than the original IP header tunnel mode is normally used between two

9:54 routers between a host and a router or between a router and a host as you can

10:01 10 minutes, 1 second observe in the figure displayed the entire original packet is protected from intrusion between the sender and the

10:10 receiver as if the whole packet goes through an imaginary tunnel now if you will compare transport and tunnel mode

10:18 in transport mode the IP security layer comes between the transport layer and the network layer internal mode the flow

10:26 is from Network layer to the IP security layer and then back to the network layer again as you can observe in the figure

10:34 it Compares tunnel mode and transparent mode now IP security defines two

10:42 protocols the authentication header protocol and encapsulating security payload ESP protocol to provide the

10:51 authentication or encryption for packets at the IP level we will discuss these protocols briefly here let's have a

10:59 quick look on authentication header first the authentication header protocol is designed to authenticate the source

11:07 and to ensure the Integrity of the payload carried in the IP packet the protocol uses a hash function and

11:15 symmetric key to create a message digest the digest is inserted in the authentication header the authentication

11:22 header is then placed in the appropriate location based on the mode whether it can be transport called tunnel mode

11:30 figure shows the field and the positions of the authentication header in the transport mode now encapsulating

11:38 security payload that is ESP the ah protocols does not provide confidentiality only source

11:46 authentication and data Integrity IP security later defines and alternative protocols that provides Source

11:56 authentication integrity and confidentiality ESP adds a header and trailer note that esp's authentication

12:05 data are added at the end of the packet which make its calculation easier as you can observe in the figure location of

12:14 ESP header and trailer now let's discuss the second security approach security at transport layer another relatively general purpose solution is to implement security just above the TCP the primary

12:21 example of this approach is SSL that is cure socket layer and the follow on internet standard known as TLS transport layer security at this level there are two implementation choices for full

12:31 Journal SSL could be provided as the part of underlying protocol seat and therefore be transparent to Applications

12:38 alternatively SSL can be embedded in specific packages for example Netscape Microsoft Explorer browsers come with

12:47 the SSL and most servers have implemented the protocol as represented in the figure the implementation of SSL

12:57 and TLS on transport layer so one of the goals of these protocols is to provide server and client authentication data

13:06 confidentiality and data Integrity application layer client server programs

13:15 such as HTTP that is hyper text transfer protocol that uses the service of TCP

13:24 can encapsulate their data in SSL Packets if the server and clients are capable of running SSL or TLS programs

13:30 then the client can use the URL https it means hyper text transfer protocol secure instead of the

13:38 HTTP that is hyper text transfer protocol that allows HTTP message to be encapsulated in SSL packets for example

13:57 credit card numbers can safely transferred via the internet for online Shoppers as you can observe in SSL

14:07 Define four protocols in two layers the record protocol is the carrier it carries messages from three other

14:15 protocols as well as the data coming from the application layer messages from the record Protocols are payload to the

14:24 transport layer normally TCP the handshake protocol provides security parameters for record protocols it

14:31

14:39 establishes a cipher set and provides key and security parameters it also authenticates the server to the client

14:46 and the client to the server if it's required the change Cipher specification protocol is used for signaling the

14:54 Readiness of the cryptographic secrets the last the alert protocol is used to report abnormal conditions now let's

15:04 discuss the security Approach at the application layer that is seventh layer in the OSI model application specific

15:12 Security Services are embedded with the particular applications the advantage of this approach is that service can be

15:20 tailored to the specific need of given application in the context of web security an important example of this

15:28 approach is secure electronic transaction set as you can observe in the figure examples of this architecture

15:37 set on the top of the HTTP this is a common implementation in some implementation set makes uses of TCP

15:45 directly two Protocols are used to provide security services for emails that is electronic mails at application

15:53 layer now first one is pretty good privacy that is pgp and SK pure multi-purpose internet mail extension

16:02 that is SM smim now let's have a brief discussion on secure electronic transaction Now set

16:10 is an open encryption and security specification designed to protect credit card transactions on the internet the

16:18 current version set one emerged from a call for security standards by MasterCard and Visa in Feb

16:27 1996 a wide range of companies were involved in developing the initial specifications including big

16:34 Blues from the America that is IBM Microsoft Netscape RSA beginning in

16:41 1996 there have been numerous tests of concept and by 1998 the first wave of

16:49 set compliant products was available set is not itself a payment system rather it is a set of security protocols and

16:57 formats that in Ables user to employ the existing credit card payment infrastructure on an open network such

17:05 as the internet in a secure fashion in ESS sense set provides three services first it provides a secure Communication

17:13 channel among all parties involved in the transaction provides trust by the use of x.509 version 3 digital

17:23 certificates it ensures privacy because the information is only available to parties in transaction when and where

17:33 necessary set incorporates the following main features number one confidentiality of information card holders account and

17:41 payment information is secured as it travel across the network an interesting and important feature of set is that it

17:49 prevents the merchant from learning the card holders credit card number this is only provided by the issuing Bank

17:56 conventional encryption by Dees is used to provide confidentiality now the second feature is integrity of data

18:05 payment information sent from card holders to Merchants includes order information personal data and payment

18:15 instructions set guarantees the these messages contents are not altered in

18:21 transmission RSA digital signature using S1 hash codes providing message

18:28 integrity certain messages are also protected by hmac using S1 that is cure hash

18:37 algorithm now the third feature is card holders account authentication set enables Merchants to verify that a card

18:45 holder is legal user of a valid card account number set uses x.509 version 3

18:52 digital certificates with RSA signatures for this purpose now fourth feature is merge Merchant authentication set

19:00 enables card holder to verify that a merchant has a relationship with the financial institution allowing it to

19:07 accept payment cards set uses x.509 version 3 digital certificates with RSD

19:14 signature for this purpose note that unlike IP security and SSL TLS set provides only one choice for each

19:22 cryptographic algorithm this makes sense because set is a single application with a single set of requirements whereas IP

19:31 security and SSL tlsr intended to support a range of applications email security at application layer can be

19:40 provided by using pgp that was invented by Phil Zimmerman to provide email with

19:46 privacy integrity and authentication pgp can be used to create a secure email messages another Security Service

19:55 designed for electronic mail is secure multipurpose internet maale extension the protocol is an enhancement of

20:04 multi-purpose internet maale extension protocol now let's discuss the next

20:11 worldwide web security approach that can be implemented in the form of firewalls

20:18 now firewall is bit different from previous worldwide web security approaches because all previous security

20:26 measures cannot prevent cender from sending the harmful messages to the system to control access to system we

20:34 need firewalls a firewall is a device usually a router or a dedicated machine

installed between the internal network

20:43 of an organization and the rest of the internet it is designed to forward some packets and filter out some others you

20:51 can observe the concept of the firewall from the figure displayed a firewall May filter all

20:58 incoming packets for a specific host or specific server such as HTTP a firewall can be used to deny access to a specific

21:08 host or a specific service in the organization a firewall is usually classified as packet filter firewalls or

21:17 proxy based firewalls first of all we will discuss packet filter firewalls a firewall can be used as a packet filter

21:26 it can forward or block packets based upon the information in the network layer and transport layer headers that

21:34 is source and destination IP address source and destination port numbers and type of protocol used that is TCP or UDP

21:42 a packet filter firewall can be a router that uses a filtering table to decide which packet must be discarded or which

21:51 must be forwarded figure shows an example of filtering table for this kind of firewall according to the figure the

21:59 following packets are filtered incoming packets from Network

22:06 13134 are blocked note that srick means the entire network of 13134 do.

22:15 0.0 will be blocked incoming packets destined for any internal talet server

22:22 at Port number 23 are blocked incoming package destined for internal host 194.

22:31 78208 are blocked the organization wants this host for internal use only outgoing

22:39 Packers destined for an HTTP sender at Port number 80 are blocked the

22:47 organization does not want employees to browse the internet note that packet filtering firewalls can be divided into

22:54 two categories static and stateful firewalls static firewalls can be implemented using routers as discussed

23:03 before but stateful firewalls can effectively implemented as Standalone firewall devices the now the next

23:12 category is proxy firewalls the most advanced kind of packet filtering mechanisms ever the packet filter

23:20 firewall is based on the information available in the network and transport layer headers that is IP address and port numbers however ever sometimes we

23:29 need to filter a message based on the information available in the message itself means at the application layer as

23:37 an example assume that an organization wants to implement the following policies regarding its web page only

23:45 those internet user who have previously established business relationship with the company can have access access to

23:52 other users must be blocked in this case a packet filter firewall is not feasible because it cannot distinguish

24:01 24 minutes, 1 second between different packets arriving at Port number 80 testing must be done at application Level using the uniform

24:09 resource locators one solution is to install a proxy computer sometime called an application Gateway also which stands

24:18 between the internal computer and the external computer this machine act as a server to client and client to server

24:26 the figure displayed shows an application Gateway implementation for hyper text transfer protocol HTTP when

24:34 the client process sends the message the application Gateway runs a server process to receive the request the

24:42 server opens the packet at the application Level and finds out if the request is legal if it is the server act

24:49 as a client process and sends the message to the real server in the external network if it is not the

24:56 message is dropped and an error message is sent to the external user in this way the requests of the external users are

25:05 filtered based on the contents at the application layer so in the conclusion we can say as the dependency on

25:14 worldwide web is increasing and crucial information is being transferred on worldwide web the need of security is

25:22 also increasing we have different approaches to address the security issues of worldwide web on Network layer

25:29 transport layer and application layer and we can use the firewalls also but still user need to be very diligent

25:37 while using the worldwide web services user awareness can protect him from many

25:43 threats so stay protected and have a happy browsing that's all for today's

25:49 session thank you for watching thank you for